

EGR6301 — Етичний хакінг

Практична робота 2: Аналіз сканування, моделювання загроз та пріоритизація атак

Тиждень 2

Орієнтовний час: 50 хвилин

Максимальний бал: 100

Потрібно: ручка/папір, довідка Nmap (надається), довідка CVSS (надається)

Здача: рукописний або друкований PDF, формат: PW2_Прізвище_Група.pdf

Викладач: Тетяна Василівна Бабенко, д.т.н., професор

Цілі навчання

1. Аналізувати вивід Nmap та ідентифікувати тип сканування за характеристиками виводу
2. Інтерпретувати інформацію про версії сервісів для оцінки ризику вразливостей
3. Застосувати концепції CVSS для пріоритизації знахідок
4. Відобразити сканувальні дії на відповідні фази PTES
5. Побудувати модель загроз на основі заданої карти сервісів
6. Написати професійні знахідки для звіту пентесту

Вправа 1 — Аналіз виводу Nmap (30 балів — 6 балів за кожен)

Розгляньте кожен зразок виводу Nmap та дайте відповіді.

Сценарій А — Визначте тип сканування

Вивід: Nmap scan report for 192.168.56.101 PORT STATE SERVICE 21/tcp open ftp 22/tcp open ssh 80/tcp open http Nmap done: 1 IP address (1 host up) scanned in 0.42 seconds

Питання: а) Сканування завершилось за 0.42 секунди. Чи може це бути -sV? Чому так/ні? б) Яка інформація ВІДСУТНЯ у цьому виводі, яку надав би -sV? с) Який прапорець Nmap найімовірніше використано?

Сценарій Б — Інтерпретація версій

Вивід: PORT STATE SERVICE VERSION 21/tcp open ftp vsftpd 2.3.4 22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 23/tcp open telnet Linux telnetd 445/tcp open netbios-ssn Samba smbd 3.X - 4.X

Питання: а) Який сервіс має НАЙВИЩИЙ ризик? Обґрунтуйте конкретним CVE. б) Чому telnet вважається ризиком, навіть без CVE? с) Samba показує '3.X - 4.X' — чому Nmap не визначив точну версію? Яке додаткове сканування допоможе?

Сценарій В — UDP інтерпретація

Вивід: PORT STATE SERVICE 53/udp open domain 67/udp open|filtered dhcps 161/udp open|filtered snmp 514/udp open|filtered syslog

Питання: а) Поясніть різницю між 'open' та 'open|filtered' для UDP. б) Чому SNMP (161) може бути значущою знахідкою? с) Як підтвердити, чи порт 161 справді відкритий?

Сценарій Г — Мережеве виявлення

Пентестер запустив: nmap -sn 10.0.5.0/24

Результат: 'Nmap done: 256 IP addresses (3 hosts up)'

Питання: а) SoW перераховує 15 серверів у 10.0.5.0/24. Відповіли лише 3. Назвіть три можливих причини. б) Що робити далі? Чи вважати інші 12 вимкненими? с) Який прапорець змусить Nmap сканувати BCIX 256 адрес?

Сценарій Д — Стратегія сканування

Обмеження пентесту: - 200 цільових IP - 6-годинне вікно (22:00-04:00) - Клієнт вимагає мінімальний вплив на мережу - Потрібна повна карта сервісів

Запроєктуйте стратегію: а) Порядок сканування? (host discovery → port scan → version detection?) б) Який -T для «мінімального впливу»? с) -p- чи top-1000? Обґрунтуйте. d) Як зберігати результати для звіту?

Вправа 2 — Моделювання загроз з карти сервісів (30 балів)

Вам надано карту сервісів з реального пентесту (спрощену). Побудуйте повну модель загроз.

Завдання 2.1 — Оцінка ризиків (15 балів)

Карта сервісів для цілі 10.0.5.50:

Порт	Сервіс	Версія	ОС: Linux 2.6.x	21/tcp	ftp	ProFTPD 1.3.3c	22/tcp	ssh	OpenSSH
7.2p2	25/tcp	smtp	Postfix smtpd	80/tcp	http	Apache 2.4.18	110/tcp	pop3	Dovecot pop3d
143/tcp	imap	Dovecot imapd	443/tcp	https	Apache 2.4.18	3306/tcp	mysql	MySQL 5.7.25	
8080/tcp	http-proxy	Squid 3.5.12							

Для КОЖНОГО з 9 сервісів: а) Оцінка ризику: Critical / High / Medium / Low / Info б) Обґрунтування одним реченням с) Чи існує відомий CVE ('Research needed' якщо не впевнені)

Представте як таблицю.

Завдання 2.2 — План атаки (15 балів)

На основі оцінки ризиків:

- а) Оберіть ТОП-3 цілі. Для кожної: - Сервіс та версія - Очікувана техніка (exploit, brute-force, misconfiguration) - Очікуваний результат (user shell, root shell, data access) - Орієнтовний час
- б) 4 години на експлуатацію. Створіть хронологію.
- с) Що робитимете у фазі Post-Exploitation?
- д) Один абзац для нетехнічного клієнта з поясненням логіки пріоритизації.

Вправа 3 — PTES та методологія (20 балів)

Дайте відповіді про методологію тестування на проникнення.

Завдання 3.1 — Сканування у рамках PTES (10 балів)

а) Nmap-сканування відноситься до якої фази PTES? Поясніть. б) Host discovery (-sn) та service detection (-sV) — різні цілі. Поясніть кожну. с) Коли сканування переходить у Threat Modeling? Що є тригером? d) Чому PTES ставить сканування ПЕРЕД експлуатацією? e) Як результати сканування використовуються у фазі Reporting?

Завдання 3.2 — Професійна етика сканування (10 балів)

а) SoW авторизує 10.0.5.0/24. Під час сканування ви виявляєте маршрут до 10.0.6.0/24, який НЕ в scope. Чи можете сканувати? б) Авторизоване вікно: 22:00-04:00. О 03:55 ваше сканування — 70%. Що робити? с) Сканування виявило, що сервер вже скомпрометований активним зловмисником. Ваш обов'язок? d) Молодший колега пропонує -T5 для прискорення. Чому це погана ідея для production?

Вправа 4 — Написання звіту (20 балів)

Напишіть професійний контент для звіту пентесту.

Завдання 4.1 — Опис знахідки (10 балів)

Напишіть професійний опис знахідки:

Сервіс: vsftpd 2.3.4 на порту 21/tcp CVE: CVE-2011-2523 CVSS Base Score: 10.0

Включіть: а) Назва знахідки (професійна) б) Серйозність з обґрунтуванням с) Опис: що це за вразливість (3–4 речення, нетехнічно) d) Технічні деталі (3–4 речення) е) Вплив: що може зробити злоумисник (3–4 речення) f) Усунення: конкретні кроки g) Посилання: CVE, релевантні джерела

Завдання 4.2 — Секція методології (10 балів)

Напишіть секцію «Методологія» (200–250 слів) для звіту пентесту про фазу сканування: а) Використані інструменти (Nmap, прапорці) б) Типи сканувань та чому с) Score сканування (IP, порти) d) Як задокументовані результати е) Як пріоритизовані знахідки

Це повинно читатися як професійний технічний текст, а не список команд.

Критерії оцінювання

Компонент	Бали	Критерії
Вправа 1 — Аналіз виводу Nmap	30	Правильна ідентифікація, технічна точність, практичне мислення
Вправа 2 — Моделювання загроз	30	Точність оцінки ризиків, якість плану атаки, реалістичність хронології
Вправа 3 — PTES та етика	20	Розуміння методології, етичне мислення, аналіз сценаріїв
Вправа 4 — Написання звіту	20	Професійний тон, технічна точність, повнота опису знахідки
РАЗОМ	100	

Інструкції з подання

- Формат: рукописний (сканований PDF) або друкований PDF
- Назва: PW2_Прізвище_Група.pdf (напр., PW2_Іванова_КБ401.pdf)
- Усі відповіді з обґрунтуванням — односкладні = нуль балів
- Можна використовувати слайди лекцій та довідки Nmap/CVSS
- Інтернет під час практичної заборонений
- Подати через Teams до дедлайну